



LIANGSHAN ENTERPRISE

# CONTINGENCY PLANS

**Date: 20th – 22nd Nov, 2024**

**Submitted to: M. Abdullah Abid**





LIANGSHAN ENTERPRISE

---

# INCIDENT RESPONSE PLAN

---



**Date: 20th Nov, 2024**

**Submitted to: M. Abdullah Abid**

# v. Incident Response Plan (IRP)

---

## 1. Introduction

In an era of increasing cyber threats, organizations must be prepared to address incidents effectively. Cybersecurity incidents not only compromise sensitive data but can also disrupt operations, damage reputation, and incur financial losses. Preventive measures such as firewalls, intrusion detection systems, and employee training can reduce risk, but no organization can eliminate it entirely.

Liangshan Enterprise acknowledges the inevitability of cyber incidents and is committed to managing them with a robust, structured, and proactive Incident Response Plan (IRP). This document details a comprehensive framework for incident handling, outlining the roles, responsibilities, and processes necessary for effective incident detection, containment, eradication, recovery, and post-incident analysis.

Key objectives of the IRP include:

- Minimizing the impact of incidents on business operations.
- Safeguarding the confidentiality, integrity, and availability of Liangshan's information assets.
- Ensuring compliance with regulatory requirements.
- Continuously improving cybersecurity defenses.

## 2. Statement of Management Commitment

Liangshan Enterprise's management is deeply committed to cybersecurity as a critical component of business resilience. The executive team ensures that:

- Adequate resources (personnel, technology, and funding) are allocated to incident response activities.
- Regular testing, training, and updates to the IRP are conducted to adapt to evolving threats.
- Compliance with regulatory and contractual obligations is maintained.
- A culture of cybersecurity awareness is fostered across the organization.

This commitment demonstrates Liangshan's dedication to protecting its clients, employees, and partners from the adverse effects of cybersecurity incidents.

### 3. Purpose

The purpose of this Incident Response Plan is to:

1. Establish a structured and efficient process for managing cybersecurity incidents.
2. Define clear roles and responsibilities for all stakeholders involved in incident response.
3. Protect critical systems, data, and operations from potential damage caused by cyber incidents.
4. Minimize downtime and ensure a rapid return to normal operations after an incident.
5. Enhance organizational learning through post-incident analysis and continuous improvement.

By adhering to this plan, Liangshan Enterprise aims to maintain trust and integrity in its operations while mitigating risks associated with cybersecurity threats.

### 4. Scope

This IRP applies to all aspects of Liangshan Enterprise's IT ecosystem, including:

- **Physical and Virtual Infrastructure:** Servers, data centers, endpoints, and cloud services.
- **Applications and Software:** Proprietary and third-party systems used in daily operations.
- **Data Assets:** Customer data, architectural designs, financial records, and intellectual property.
- **Personnel:** Employees, contractors, and third-party vendors with access to Liangshan's systems.

The IRP addresses a wide range of incidents, including unauthorized access, data breaches, ransomware attacks, denial-of-service attacks, and insider threats

### 5. Definitions and Acronyms

The following table consists of explanation terms and jargons that would be used in the incident response plan.

| Term                           | Definition                                                                                         |
|--------------------------------|----------------------------------------------------------------------------------------------------|
| <i>Cyber Incident</i>          | Any event that compromises the confidentiality, integrity, or availability of Liangshan’s systems. |
| <i>Ransomware</i>              | Malware that encrypts data, demanding payment for decryption.                                      |
| <i>Denial of Service (DoS)</i> | An attack aimed at overwhelming systems, rendering services inaccessible.                          |
| <i>IRT</i>                     | Incident Response Team responsible for coordinating and managing incident response efforts.        |
| <i>CISO</i>                    | Chief Information Security Officer responsible for cybersecurity oversight.                        |
| <i>SIEM</i>                    | Security Information and Event Management system used for real-time monitoring and analysis.       |
| <i>Forensic Analysis</i>       | The process of collecting, preserving, and analyzing digital evidence to understand an incident.   |

**Table 5.1 Definitions and Acronyms**

## 6. Incident Response Policy

Liangshan Enterprise recognizes the critical importance of cybersecurity in protecting its business operations, clients, and reputation. The organization is committed to:

- **Rapid Detection:** Implementing advanced tools and techniques to identify threats in real time.
- **Prompt Response:** Mobilizing resources immediately to contain and mitigate incidents.
- **Effective Communication:** Ensuring timely and transparent communication with stakeholders.
- **Clear Accountability:** Assigning well-defined roles to members of the IRT.
- **Continuous Improvement:** Learning from incidents to strengthen defenses and enhance response capabilities.
- **Regulatory Compliance:** Adhering to legal obligations and industry standards for reporting and managing incidents.
- **Employee Awareness:** Conducting regular training to keep employees informed about evolving threats and response protocols.

## 7. Incident Response Team (IRT)

The IRT is composed of skilled professionals with defined roles and responsibilities to manage incidents effectively.

| Role                             | Responsibilities                                                                          | Contact Details                                                                                                                                                                  |
|----------------------------------|-------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>Incident Response Manager</i> | Oversees all response activities, assigns priorities, and ensures accurate documentation. | <b>Name:</b> Liang Wei<br><b>Title:</b> IR Manager<br><b>Location:</b> Beijing, HQ<br><b>Phone:</b> +86-10-1234-5678<br><b>Email:</b> lwei@liangshan.com                         |
| <i>Head of Security Ops</i>      | Evaluates risk, provides guidance, and manages internal training programs.                | <b>Name:</b> Rachel Smith<br><b>Title:</b> Head of Security Operations<br><b>Location:</b> London Office<br><b>Phone:</b> +44-20-7946-5678<br><b>Email:</b> rsmith@liangshan.com |
| <i>Lead Security Analyst</i>     | Conducts technical analysis, collects evidence, and determines the root cause.            | <b>Name:</b> Ethan Chen<br><b>Title:</b> Lead Security Analyst<br><b>Location:</b> New York Office<br><b>Phone:</b> +1-212-555-7890<br><b>Email:</b> echen@liangshan.com         |
| <i>IT Representative</i>         | Implements system shutdowns, provides network logs, and assists in recovery efforts.      | <b>Name:</b> Ahmed Faisal<br><b>Title:</b> IT Representative<br><b>Location:</b> Dubai Office<br><b>Phone:</b> +971-4-234-5678<br><b>Email:</b> afaisal@liangshan.com            |
| <i>Legal Advisor</i>             | Ensures compliance with legal requirements and oversees regulatory reporting.             | <b>Name:</b> Emily Taylor<br><b>Title:</b> Legal Advisor<br><b>Location:</b> London Office<br><b>Phone:</b> +44-20-7946-5680<br><b>Email:</b> etaylor@liangshan.com              |

| Role                             | Responsibility                                                                                   | Contact Details                                                                                                                                                                                |
|----------------------------------|--------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <i>PR/Communications Officer</i> | Manages communications with stakeholders, including employees, clients, and the media.           | <b>Name:</b> Mia Rodriguez<br><b>Title:</b> PR/Communications Officer<br><b>Location:</b> New York Office<br><b>Phone:</b> +1-212-555-1234<br><b>Email:</b> mrodriguez@liangshan.com           |
| <i>Data Protection Officer</i>   | Advises on data breach disclosures and ensures alignment with data protection laws (e.g., GDPR). | <b>Name:</b> Clara Zhang<br><b>Title:</b> Data Protection Officer<br><b>Location:</b> Beijing, HQ<br><b>Phone:</b> +86-10-5678-1234<br><b>Email:</b> czhang@liangshan.com                      |
| <i>Digital Forensics Partner</i> | Provides technical expertise in incident containment and forensic investigations.                | <b>Name:</b> Forensic Experts Ltd.<br><b>Title:</b> Digital Forensics Partner<br><b>Location:</b> London Office<br><b>Phone:</b> +44-20-7946-1122<br><b>Email:</b> support@forensicexperts.com |
| <i>CISO</i>                      | Ensures alignment between incident response and broader cybersecurity strategy.                  | <b>Name:</b> Mark Tan<br><b>Title:</b> Chief Information Security Officer<br><b>Location:</b> Beijing, HQ<br><b>Phone:</b> +86-10-2345-6789<br><b>Email:</b> mtan@liangshan.com                |

**Table 5.2 Incident Response Team Contact Information**

## 8. Incident Identification

Liangshan uses a multi-layered approach to detect incidents, employing:

- **SIEM Tools:** Real-time monitoring of logs and alerts.
- **EDR Systems:** Detection of endpoint-based threats.
- **IDS/IPS:** Monitoring network traffic for suspicious activity.
- **User Reports:** Employees are trained to recognize and report anomalies.

Detected incidents are logged into a centralized case management platform (e.g., ServiceNow) for efficient tracking and resolution.

## 9. Incident Classification

Incidents are classified based on severity and impact:

| Severity              | SLA                                                                                | Description                                                                                                                                                              | Impact                                                                                                                                                                                                                                                                                                                                                 |
|-----------------------|------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P1 Critical</b>    | <b>Response Time:</b><br>20 minutes<br><b>Resolution Time:</b><br>4 hours          | An incident that is disrupting Liangshan's core services or affects any internal/external business that leads to significant financial loss.                             | <ul style="list-style-type: none"> <li>Severe financial loss</li> <li>Long-term reputation damage.</li> <li>Over 50% of the workforce cannot work, or critical systems cannot be accessed for an unknown period of time.</li> </ul>                                                                                                                    |
| <b>P2 Significant</b> | <b>Response Time:</b><br>30 minutes<br><b>Resolution Time:</b><br>8 hours          | An incident that has a serious impact on Liangshan's business operation, affects internal business functions, and leads to financial loss or serious reputational damage | <ul style="list-style-type: none"> <li>Liangshan's internal business functions have been disrupted, and the ability to perform some services has been lost.</li> <li>Sensitive data has been accessed or exfiltrated.</li> <li>Recovery is unpredictable, and additional resources or help is needed.</li> <li>Serious reputational damage.</li> </ul> |
| <b>P3 Moderate</b>    | <b>Response Time:</b><br>24 hours<br><b>Resolution Time:</b><br>5 Business Days    | An incident that has a substantial or moderate impact on internal business operations, but core services to external parties are still functioning as usual.             | <ul style="list-style-type: none"> <li>Liangshan's internal business functions have been disrupted.</li> <li>More than 10% of the workforce cannot work or access critical systems.</li> <li>Time to recovery is predictable but may need additional resources and help.</li> </ul>                                                                    |
| <b>P4 Minor</b>       | <b>Response Time:</b><br>24 hours<br><b>Resolution Time:</b><br>5-10 Business Days | An incident that has limited impact on certain individuals or systems and has no other impact on business operations or concerns to external parties.                    | <ul style="list-style-type: none"> <li>Minimal effect on internal business functions.</li> <li>Less than 10% of the workforce is unable to work or access the required systems for a short period of time.</li> <li>Time to recover is predictable with existing resources</li> </ul>                                                                  |

**Table 5.3 Incident Classification Table**



## 10. Incident Response Process

Liangshan Enterprise adheres to a structured and comprehensive incident response process to address and resolve cybersecurity incidents effectively. This process follows established best practices and ensures minimal disruption to operations while safeguarding sensitive data. The phases of incident resolution include:

- **Preparation**
- **Detection and Analysis**
- **Containment, Eradication, and Recovery**
- **Post-Incident Activity**

Each phase is detailed below with measures and techniques tailored to Liangshan's operational environment.

### 10.1 Preparation

Preparation is the foundation of an effective incident response strategy. Liangshan Enterprise takes proactive measures to mitigate the risk of incidents and ensure readiness to respond. The following actions are implemented:

- **Security Tool Deployment:**
  - Advanced tools such as firewalls, Security Information and Event Management (SIEM) systems, Web Application Firewalls (WAF), Endpoint Detection and Response (EDR), and Intrusion Detection/Prevention Systems (IDS/IPS) are deployed for real-time threat monitoring and prevention.
  - Multi-factor authentication (MFA) and Zero Trust Architecture (ZTA) are enforced across all systems.
- **Regular Assessments and Simulations:**
  - Penetration testing, vulnerability scans, and tabletop exercises are conducted quarterly to identify weaknesses and test incident response capabilities.
  - Simulations of specific threats (e.g., ransomware attacks, insider breaches) are performed to evaluate team readiness.
- **Employee Training and Awareness:**
  - Comprehensive training programs focus on phishing awareness, secure handling of sensitive information, and incident reporting protocols.
  - Regular awareness campaigns, such as simulated phishing attacks, are conducted to enhance employee vigilance.

- **Incident Response Toolkit:**
  - Maintain a ready-to-deploy incident response toolkit, including forensic software, network analyzers, and live recovery scripts, to facilitate rapid response.
- **Data Backup and Recovery:**
  - Regularly updated and securely stored backups ensure data integrity and availability during recovery.
  - Offsite and cloud-based backups are encrypted and tested for reliability.

## 10.2 Detection and Analysis

Timely detection and accurate analysis of incidents are critical to minimizing impact. Liangshan Enterprise employs the following methods and tools:

- **Continuous Monitoring:**
  - Real-time monitoring of system logs, network traffic, and user activities using SIEM tools to identify unusual behavior.
  - Integration of machine learning models for anomaly detection.
- **Threat Intelligence Integration:**
  - Leverage global threat intelligence feeds to identify emerging threats and proactively defend against known vulnerabilities.
- **Incident Triage:**
  - Incidents are categorized by severity and type (e.g., malware, unauthorized access, data breach).
  - Root cause analysis determines the attack vector, affected assets, and potential impacts.
- **Automated Alerts:**
  - Automated alerting systems notify the Incident Response Team (IRT) of potential threats for immediate investigation.
- **User Reports:**
  - Employees are encouraged to report suspicious activities through a dedicated reporting platform.

## 10.3 Containment, Eradication, and Recovery

### 10.3.1 Containment

The containment phase focuses on limiting the spread of an incident and preventing further damage. Liangshan employs the following techniques:

- **Endpoint Isolation:**
  - Compromised endpoints are immediately disconnected from the network to contain the threat.

- **Network Segmentation:**
  - Affected network segments are quarantined to prevent lateral movement of the attack.
- **Access Revocation:**
  - Disable compromised accounts and revoke access to sensitive systems for impacted users.
- **Traffic Filtering:**
  - Block malicious IP addresses, domains, and protocols at the firewall and IDS/IPS levels.
- **System Snapshots:**
  - Capture snapshots of affected systems to preserve forensic evidence for further analysis.

### 10.3.2 Eradication

After containment, the eradication phase ensures complete removal of the threat. Methods include:

- **Malware Removal:**
  - Use anti-virus (AV) tools and manual processes to identify and remove malware.
- **Account Remediation:**
  - Reset credentials for all compromised accounts and strengthen authentication mechanisms.
- **Patch Management:**
  - Identify and patch vulnerabilities exploited during the attack across affected systems.
- **Infrastructure Cleanup:**
  - Scan for backdoors, rogue accounts, or other remnants of the attack.

### 10.3.3 Recovery

The recovery phase restores normal operations while ensuring that systems are secure. Liangshan implements the following measures:

- **Service Restoration:**
  - Restore affected services and systems using validated backups to maintain data integrity.
- **Heightened Monitoring:**
  - Deploy enhanced monitoring tools and processes during the recovery period to detect any residual threats.

- **Incremental Reintroduction:**
  - Systems and services are incrementally reconnected to the network to minimize potential risks.
- **Post-Recovery Validation:**
  - Conduct thorough testing to confirm the operational integrity of all restored systems.

## 10.4 Post-Incident Activity

The post-incident activity phase focuses on organizational learning and process improvement. Liangshan adopts a systematic approach:

- **Comprehensive Post-Mortem Review:**
  - Analyze the incident in detail, including root cause, affected systems, response effectiveness, and impact.
- **Lessons Learned Documentation:**
  - Develop a detailed report summarizing findings, challenges encountered, and corrective actions.
- **Policy and Process Updates:**
  - Revise security policies, response procedures, and training programs based on lessons learned.
- **Employee Feedback:**
  - Gather input from IRT members and affected employees to refine response strategies.
- **Preventive Measures:**
  - Implement additional safeguards to prevent recurrence, such as improving system configurations, deploying new tools, or upgrading infrastructure.
- **Report Sharing:**
  - Share findings with relevant stakeholders, including management, regulatory bodies, and third-party vendors, to ensure accountability and transparency.

## 11. Communication Plan

Liangshan's IRP Communication Plan outlines the strategies, procedures, and roles for effective communication during cybersecurity incidents. The plan aims to maintain transparency, inform stakeholders promptly, and facilitate efficient collaboration among IRT members. Key objectives are:

1. **Timely Notification:** Ensure prompt notification and information sharing during incidents.
2. **Clear Roles:** Define the roles and responsibilities of individuals and teams involved in communication.

3. **Consistent Messaging:** Provide consistent and accurate information to all stakeholders.
4. **External Relations:** Manage external communications with regulatory bodies, partners, vendors, and the public.

**[a] Communication Team**

| Role                               | Name          | Title                              |
|------------------------------------|---------------|------------------------------------|
| <i>CISO</i>                        | Mark Tan      | Chief Information Security Officer |
| <i>Incident Response Manager</i>   | Liang Wei     | IR Manager                         |
| <i>PR/Communications Officer</i>   | Mia Rodriguez | PR/Communications Officer          |
| <i>Head of Security Operations</i> | Rachel Smith  | Head of Security Operations        |
| <i>Lead Security Analyst</i>       | Ethan Chen    | Lead Security Analyst              |
| <i>Legal Advisor</i>               | Emily Taylor  | Legal Advisor                      |
| <i>Designate spokesperson</i>      | Clara Zhang   | Data Protection Officer            |

***Table 5.4 Communication Team Contact Information***

**[b] Documentation and Record Keeping**

All communication related to the incident should be documented in detail, including date, time, content, and recipients. These records should be maintained for legal and regulatory compliance.

**[c] Testing and Drills**

Periodic testing and drills of the communication plan must be conducted to ensure the readiness of the IRT.

## [d] Plan Review

The communication plan should be reviewed and updated as necessary to address evolving threats and improve response effectiveness.

## 11.1 Internal Communication

### 11.1.1 Incident Reporting

- Employees must report any potential cybersecurity incidents to the Liangshan Enterprise Incident Response Team (IRT) immediately.
- Reports should be sent via:
  - **Contact Information:**
    - **Phone:** +86-10-1234-5678
    - **Email:** incident@liangshan.com
- The incident will be documented using the **Incident Reporting Form**, available on the company intranet or the IRT portal.

### 11.1.2 Incident Response Team Activation

- The **Incident Response Manager**, Liang Wei, will activate the IRT upon receiving a confirmed report of an incident.
- Notification to team members will be sent through **Microsoft Teams** (primary) and **SMS alerts** (secondary) to ensure rapid communication.

### 11.1.3 Incident Updates

- The **Lead Security Analyst**, Ethan Chen, will provide regular updates to the IRT regarding incident status, findings, and mitigation progress.
- Updates will be communicated via **Microsoft Teams Channels** and **secure email chains** to ensure all stakeholders remain informed.

### 11.1.4 Escalation Procedures

- The IRT will escalate incidents classified as **Severity P1 or P2** to:
  - The CISO (Mark Tan) for immediate executive oversight.
  - The Legal Advisor (Emily Taylor) for regulatory compliance and reporting.
- Escalation will follow the predefined **Critical Incident Playbook**, which outlines priority actions and contact protocols.

## 11.2 External Communication

### 11.2.1 Notification to Regulatory Bodies

- The **Legal Advisor**, Emily Taylor, will evaluate whether regulatory bodies must be informed based on:
  - Applicable laws (e.g., GDPR, CCPA).
  - Nature and scope of the incident (e.g., data breach involving sensitive information).
- Notifications, if required, will be sent via secure communication channels as mandated by the relevant authorities.

### 11.2.2 Partners and Vendors

- The **PR/Communications Officer**, Mia Rodriguez, will coordinate communication with partners and vendors to:
  - Notify them of any potential impact on shared services or data.
  - Provide updates on mitigation actions being taken by Liangshan Enterprise.

### 11.2.3 Public Announcement

- In incidents that may affect customers or public stakeholders, Liangshan Enterprise will issue a public announcement through the **Designated Spokesperson**, Clara Zhang.
- The announcement will:
  - Provide a concise summary of the incident without revealing sensitive details.
  - Assure stakeholders of Liangshan's commitment to resolution and transparency.
  - Be shared via the official company website and verified social media accounts.

## 12. Maintenance and Review

To ensure the effectiveness and relevance of the Cyber Incident Response Plan (IRP), Liangshan Enterprise commits to a structured process of regular review and maintenance. This process ensures that the IRP remains aligned with evolving cyber threats, organizational changes, and regulatory requirements.

### 12.1 Review Schedule

- **Auditor:** The Information Security Team (IST) is responsible for auditing the IRP to identify gaps, ensure compliance, and recommend updates.
- **Frequency:** The IRP will be reviewed:
  - **Annually** as part of routine cybersecurity governance.

- **As Required** in response to:
  - Changes in organizational structure or technology.
  - Significant cybersecurity incidents.
  - Updates to regulatory or industry standards.

## 12.2 Review Objectives

The review process aims to:

- Validate the relevance of incident response procedures.
- Ensure roles and responsibilities remain accurate and actionable.
- Assess the adequacy of tools and resources allocated for incident response.
- Incorporate lessons learned from previous incidents and tabletop exercises.
- Align the IRP with the latest threat intelligence and best practices.

## 12.3 Documentation and Approval

- A formal **Review Report** will be prepared after each audit, detailing:
  - Observations.
  - Recommended updates.
  - Action plans for implementation.
- The updated IRP will be approved by:
  - The **CISO** (Chief Information Security Officer).
  - The Executive Leadership Team.

## 12.4 Key Dates

- **Last Review Date:** 01/11/2024
- **Next Scheduled Review Date:** 31/12/2024

## 12.5 Testing and Validation

- **Simulated Exercises:** Periodic incident response drills will be conducted to test the IRP's effectiveness.
- **Stakeholder Feedback:** Input from the IRT and key stakeholders will be solicited to identify practical improvements.
- **Metrics:** Performance metrics (e.g., response time, resolution time) will be analyzed to refine processes.



# 13. Case 1: Ransomware Attack on Critical Systems

---

## 13.1 Incident Overview

On a Monday morning, employees at Liangshan Enterprise report being unable to access files on the company's shared drive. Instead of the usual file names, encrypted files display a ".locked" extension along with a ransom note demanding 10 Bitcoin for decryption keys. The note threatens to permanently delete files if the ransom is not paid within 72 hours.

The ransomware attack originates from an employee inadvertently opening a malicious email attachment. The attack quickly spreads across the network, encrypting data on multiple servers, including critical architectural designs and financial records stored in Liangshan's Beijing data center.

## 13.2 Incident Response Plan Execution

### 13.2.1 Incident Identification

- **Detection:** Liangshan's Security Information and Event Management (SIEM) system detects abnormal file activity and generates high-priority alerts.
- **Reporting:** The affected employees contact the **Incident Response Manager (Liang Wei)** at the Beijing HQ to report the incident and email screenshots of the ransom note to the Incident Response Team (IRT).
- **Initial Triage:**
  - The **Lead Security Analyst (Ethan Chen)** confirms suspicious activity by analyzing SIEM logs, identifying unusual file encryption patterns originating from an endpoint.
- **Case Logging:** The Incident Response Manager logs the incident into ServiceNow for tracking and assigns a Severity P1 classification.

### 13.2.2 Incident Classification

- **Severity P1 - Critical Incident:**

As mentioned, **Incident Response Manager (Liang Wei)** assigned the incident P1 classification. The reasons behind the ticketing are listed below:

1. Essential services (e.g., architectural design access) are disrupted.
2. Over 50% of employees cannot access critical systems.
3. Classified data (e.g., client contracts, architectural models) is at risk of permanent loss.

### 13.2.3 IRT Activation

- The **Incident Response Manager (Liang Wei)** activates the IRT, notifying team members via Microsoft Teams and SMS alerts.
- **CISO (Mark Tan)** is informed immediately due to the critical nature of the attack.
- The **PR/Communications Officer (Mia Rodriguez)** is looped in to prepare external communication in case public disclosure becomes necessary.

### 13.2.4 Containment

- **Endpoint Isolation:**
  - The **IT Representative (Ahmed Faisal)** isolates the infected endpoint immediately and disconnects it from the network using the Endpoint Detection and Response (EDR) tools.
- **Network Segmentation:**
  - Firewall rules are updated by the **Head of Security Operations (Rachel Smith)** to block traffic from compromised systems. Network traffic to and from the affected servers is blocked, preventing lateral movement of the ransomware.
- **Access Revocation:**
  - Accounts linked to the affected endpoint are disabled to prevent further spread.
- **Snapshot Capture:**
  - The **Digital Forensics Partner (Forensic Experts Ltd.)** captures forensic snapshots of the compromised endpoint to preserve evidence.

### 13.2.5 Eradication

- **Forensic Analysis:**
  - The **Digital Forensics Partner (Forensic Experts Ltd.)** investigates to identify the ransomware variant and its attack vector.
- **Malware Removal:**
  - The **Lead Security Analyst (Ethan Chen)** deploys anti-malware tools to remove ransomware remnants from infected endpoints.
- **Patch Management:**
  - The **IT Representative (Ahmed Faisal)** patches vulnerabilities that allowed the ransomware entry, including updates to outdated systems.
- **Credential Reset:**
  - Affected accounts have their credentials reset, with **Data Protection Officer (Clara Zhang)** ensuring compliance with privacy laws.

### 13.2.6 Recovery

- **Data Restoration:**
  - The **Head of Security Operations (Rachel Smith)** coordinates the restoration of data the most recent offsite backups to ensure integrity.
- **Heightened Monitoring:**
  - Systems are placed under intensive monitoring using SIEM and EDR tools to detect potential residual threats.
- **Incremental Reconnection:**
  - Clean systems are reintroduced incrementally into the network to minimize risk.

### 13.2.7 Post-Incident Activity

- **Post-Mortem Review:**
  - The IRT conducts a detailed analysis to identify gaps, led by **CISO (Mark Tan)**.
- **Training:**
  - **PR/Communications Officer (Mia Rodriguez)** announces a company-wide training on ransomware awareness.
- **Policy Update:**
  - Email attachment scanning policies are revised, ensuring stricter protocols for phishing prevention.

## 14. Case 2: Insider Threat and Data Exfiltration

---

### 14.1 Incident Overview

An internal yet anonymous whistleblower alerts Liangshan's **Data Protection Officer (Clara Zhang)** about a suspicious activity by an employee in the Dubai office. The employee, a contractor with limited access, is seen downloading unusually large volumes of proprietary data, including architectural blueprints and Building Information Models (BIM), onto a personal USB drive. The incident raises concerns of intellectual property theft intended for a competitor.

### 14.2 Incident Response Plan Execution

#### 14.2.1 Incident Identification

- **Detection:** Liangshan's DLP (Data Loss Prevention) system flags unauthorized data downloads and USB device usage.

- **Reporting:** An anonymous whistleblower reports suspicious behavior directly to the Data Protection Officer (Clara Zhang) through email.
- **Initial Triage:**
  - Lead Security Analyst (Ethan Chen) confirms the anomaly and validates the whistleblower's report by reviewing DLP logs.
- **Case Logging:** The Incident Response Manager logs the case in ServiceNow with a Severity P2 classification.

### 14.2.2 Incident Classification

- **Severity P2 - Significant Incident:**

As mentioned, Incident Response Manager (Laing Wei) assigned the incident P2 classification. The reasons behind the ticketing are listed below

- Sensitive client data and intellectual property are at risk of exposure.
- The internal business function (data security) is compromised.
- Recovery requires immediate action to prevent further exfiltration.

### 14.2.3 IRT Activation

- The **Incident Response Manager (Liang Wei)** is immediately informed and activates the IRT.
- **CISO (Mark Tan)** and **Legal Advisor (Emily Taylor)** are notified due to potential legal implications of intellectual property theft.

### 14.2.4 Containment

- **Access Revocation:**
  - The **IT Representative (Ahmed Faisal)** disables the contractor's account and restricts physical access to the office.
- **Device Seizure:**
  - The **Digital Forensics Partner (Forensic Experts Ltd.)** confiscates the employee's workstation and USB drive for forensic examination.
- **Endpoint Monitoring:**
  - The **Head of Security Operations (Rachel Smith)** enhances network monitoring for signs of further suspicious activity.

### 14.2.5 Eradication

- **Log Analysis:**
  - The **Lead Security Analyst (Ethan Chen)** examines server logs to identify other accounts or systems accessed by the rogue contractor's and close any loopholes that allowed excessive data access.
- **Infrastructure Cleanup:**
  - All systems accessed by the contractor are scanned for unauthorized changes or malware.
- **Policy Enforcement:**
  - Access permissions are reviewed and adjusted to align with the principle of least privilege.

### 14.2.6 Recovery

- **Data Validation:**
  - The **Data Protection Officer (Clara Zhang)** ensures all downloaded files remain uncompromised and protected. She also ensures that backups are compared with live data to confirm that no tampering occurred.
- **Enhanced DLP Rules:**
  - The DLP system is updated to enforce stricter rules for USB usage and flag any future large-scale data transfers more aggressively.
- **Network Monitoring:**
  - Advanced monitoring tools are deployed to identify ongoing insider threats.

### 14.2.7 Post-Incident Activity

- **Policy Updates:**
  - **CISO (Mark Tan)** oversees updates to access control policies, reinforcing the principle of least privilege. He also foresees Liangshan's Access Control Policy update to include more rigorous periodic access reviews.
- **Whistleblower Recognition:**
  - **PR/Communications Officer (Mia Rodriguez)** ensures the whistleblower is acknowledged anonymously, promoting trust in Liangshan's reporting mechanisms.
- **Employee Training:**
  - Training sessions on ethical conduct and data security are made mandatory for all contractors and employees.
- **Disciplinary Action:**
  - The **Legal Advisor (Emily Taylor)** ensures that appropriate disciplinary and legal measures are taken against the rogue contractor.